MoneyMoney

דו״ח אבטחת מידע ופרטיות

סקירה טכנית של אמצעי ההגנה על נתוני המשתמש באפליקציה

גרסה: 1.0 **תאריך:** מרץ 2026 **סיווג:** פומבי **גרסה שנבדקה:** v1.0.16

Claude Opus 4.6 — מודל שפה מבית Anthropic

סקירת קוד מקור אוטומטית | מרץ 2026 | גרסה שנבדקה: **v1.0.16**

מתודולוגיה: דו״ח זה נכתב על בסיס סקירה ישירה של קוד המקור בכל שלושת חבילות הפרויקט (main, preload, renderer). נבדקו קבצי ההצפנה, פונקציות הגריפה, שליחת הנתונים ל-Base44, הגדרות אבטחת Electron, והרשאות הניווט. כל הממצאים מבוססים על הקוד בפועל — לא על תיעוד או הצהרות.

הצהרת עצמאות הסוקר

- **עצמאות:** סקירה זו בוצעה באופן עצמאי לחלוטין. מפתח האפליקציה לא הכתיב, הגביל, או השפיע על הממצאים המפורטים בדו״ח.
- **גישה מלאה:** ניתנה גישה מלאה ובלתי מוגבלת לכל קוד המקור של המאגר, כולל כל שלוש חבילות הפרויקט (main, preload, renderer), קבצי הגדרות, וסקריפטי בנייה.
- **ללא הטעיה:** הסוקר לא הוטעה, הונחה, או קיבל קוד סלקטיבי לבדיקה. כל קבצי המאגר היו זמינים לסקירה ללא חריגה.
- **ממצאים עצמאיים:** כל הממצאים המופיעים בדו״ח זה מייצגים ניתוח עצמאי של הסוקר בלבד, על בסיס בחינה ישירה של קוד המקור — לא על בסיס הצהרות או תיעוד של המפתח.

Claude Opus 4.6

Claude Opus 4.6 — Anthropic
Automated Source Code Security Review
March 2026

הבהרה: דו״ח זה הופק על ידי מודל בינה מלאכותית (AI). הוא מבוסס על ניתוח סטטי של קוד המקור ואינו מהווה תחליף לבדיקת חדירה (penetration test) מקצועית או ביקורת אבטחה פורמלית. הקוד פתוח ומומלץ לכל מי שמעוניין לבצע אימות עצמאי.

סיכום מנהלים

MoneyMoney היא אפליקציה שרצה באופן מלא על המחשב שלכם. פרטי ההתחברות לבנקים **מוצפנים בהצפנת AES-256** ונשמרים רק על המחשב המקומי. הסיסמאות **נשלחות רק ישירות לאתרי הבנקים** — בדיוק כמו כניסה ידנית. שום סיסמה, שם משתמש, או תעודת זהות **לא נשלחים לשום צד שלישי**, כולל שרתי MoneyMoney. סנכרון העסקאות שולח רק נתוני עסקה (תאריך, סכום, תיאור) כאשר **מספרי חשבון מקוצרים ל-4 ספרות אחרונות בלבד**. האפליקציה היא קוד פתוח — כל אחד יכול לבדוק את הקוד.

פרק 1

אחסון פרטי התחברות

פרטי ההתחברות לבנקים ולחברות האשראי (שם משתמש, סיסמה, תעודת זהות) מוצפנים לפני שמירתם על המחשב. ההצפנה מתבצעת באמצעות אלגוריתמים מוכרים ומאובטחים ברמה בנקאית.

הצפנת AES-256-CTR עם גזירת מפתח scrypt

קובץ ההגדרות כולו — כולל כל פרטי ההתחברות — מוצפן באמצעות אלגוריתם `AES-256-CTR`. מפתח ההצפנה נגזר באמצעות פונקציית `scrypt` (אלגוריתם עמיד בפני מתקפות כוח גס). לכל הצפנה נוצר וקטור אתחול (IV) אקראי ייחודי באורך 128 סיביות.

מפתח ההצפנה מוגן על ידי מערכת ההפעלה

ה-Salt (ערך אקראי המשמש לגזירת מפתח ההצפנה) נשמר ב-**Windows Credential Manager** — מנגנון מאובטח המובנה במערכת ההפעלה. גם אם מישהו יקבל גישה לקובץ ההגדרות המוצפן, הוא לא יוכל לפענח אותו ללא גישה לחשבון המשתמש במערכת ההפעלה.

פירוט טכני

Algorithm: AES-256-CTR | Key derivation: scrypt (32-byte key) | IV: 128-bit random per encryption | Salt storage: Windows Credential Manager (keytar, service: "MoneyMoney") | Full config file encrypted at rest

פרק 2

תהליך שליפת העסקאות מהבנקים

שליפת העסקאות מתבצעת באופן מקומי לחלוטין על המחשב שלכם, באמצעות דפדפן Chromium מובנה (Puppeteer). התהליך זהה לכניסה ידנית לאתר הבנק — ובדיוק כמו כניסה ידנית, הסיסמה נשלחת רק לאתר הבנק עצמו.

גריפה מקומית — ללא שרת מתווך

האפליקציה מפעילה דפדפן Chromium מקומי (מורד ומאוחסן על המחשב שלכם) ונכנסת דרכו ישירות לאתרי הבנקים. אין שרת מתווך. אין פרוקסי. הסיסמה עוברת מהמחשב שלכם ישירות לשרתי הבנק — בדיוק כמו כניסה רגילה מ-Chrome. התהליך מבוסס על ספריית `israeli-bank-scrapers-core` בקוד פתוח.

הסיסמאות לא נשלחות לאף צד שלישי

בקוד המקור, פרטי ההתחברות (`credentials`) מועברים רק לפונקציית הגריפה המקומית — שמזינה אותם ישירות באתר הבנק דרך הדפדפן המובנה. אין בקוד שום שליחה של סיסמאות לשרתים חיצוניים, לשרתי MoneyMoney, או לכל כתובת אחרת.

פרק 3

סנכרון נתונים ל-MoneyMoney

כאשר הסנכרון מופעל, האפליקציה שולחת לשרתי MoneyMoney רק את נתוני העסקאות — ללא שום פרט מזהה של חשבון הבנק. מספרי חשבון מקוצרים כך שנשלחות רק 4 הספרות האחרונות.

נשלח ל-MoneyMoney

- ✓ תאריך עסקה
- ✓ תיאור עסקה
- ✓ סכום ומטבע
- ✓ קטגוריה
- ✓ 4 ספרות אחרונות של חשבון

לעולם לא נשלח

- ✗ שם משתמש / סיסמה
- ✗ תעודת זהות
- ✗ קוד אימות / OTP
- ✗ מספר חשבון מלא
- ✗ מספר כרטיס אשראי

פירוט טכני

בקוד המקור, מספר החשבון מקוצר באופן מפורש: `accountNumber.slice(-4)`. מספר החשבון המלא לעולם לא נשלח מחוץ למחשב. השליחה מתבצעת דרך חיבור HTTPS מוצפן לשרתי MoneyMoney בלבד.

פרק 4

אבטחת האפליקציה (Electron)

האפליקציה בנויה על פלטפורמת Electron ומיישמת את כל הגנות האבטחה המומלצות למניעת הזרקת קוד זדוני והגבלת הרשאות.

הגדרת אבטחה	ערך	משמעות
`nodeIntegration`	מושבת	ממשק המשתמש לא יכול להריץ קוד מערכת
`contextIsolation`	מופעל	הפרדה מלאה בין קוד האפליקציה לממשק
`webviewTag`	מושבת	אי אפשר להטמיע דפי אינטרנט חיצוניים
הגבלת ניווט	מופעל	חסימת ניווט לאתרים שאינם ברשימת ההיתר
הגבלת הרשאות	מופעל	בקשות הרשאות (מצלמה, מיקום וכו׳) נחסמות אוטומטית

הגבלת תקשורת חיצונית

האפליקציה חוסמת כל ניווט לכתובות שאינן ברשימה מוגדרת מראש. בגרסת הייצור, רשימת ההיתר ריקה — כלומר אי אפשר לנווט לשום אתר חיצוני מתוך האפליקציה. קישורים חיצוניים (כמו GitHub) נפתחים בדפדפן ברירת המחדל של המחשב, לא בתוך האפליקציה.

פרק 5

ללא מעקב ואיסוף נתונים

אפס איסוף נתונים — אין אנליטיקס, אין טלמטריה

האפליקציה לא מכילה שום קוד לאיסוף נתונים, מעקב שימוש, או דיווח שגיאות לשרתים חיצוניים. כל מערכות האנליטיקס (כגון Sentry) הוסרו מהקוד לחלוטין. אין פיקסלים של מעקב, אין Google Analytics, אין שום דיווח "הביתה". האפליקציה לא שולחת שום מידע ללא ידיעתכם — ניתן לאמת זאת בקוד המקור הפתוח.

פרק 6

קוד פתוח ושקיפות

הקוד פתוח לעיון הציבור

כל קוד המקור של MoneyMoney זמין באופן פומבי ב-GitHub. כל אדם בעל ידע טכני יכול לבדוק, לאמת, ולוודא שהאפליקציה עושה בדיוק מה שמתואר בדו״ח זה. הגריפה מהבנקים מבוססת על ספריית `israeli-bank-scrapers-core` — פרויקט קוד פתוח ישראלי מוכר שבשימוש נרחב.

פרק 7

נקודות לתשומת לב

לשם שקיפות מלאה, להלן מספר נקודות שחשוב להכיר:

קובץ העסקאות המקומי אינו מוצפן

קובץ ה-JSON המכיל את העסקאות שנשלפו נשמר ללא הצפנה על המחשב המקומי. הקובץ מכיל נתוני עסקאות בלבד (תאריך, סכום, תיאור) — **לא פרטי התחברות**. מי שיש לו גישה למחשב שלכם יכול לקרוא את קובץ העסקאות. זהו קובץ מקומי שלא נגיש מרחוק.

יומני שגיאות מקומיים

במקרה של שגיאה, האפליקציה עשויה לכתוב פרטי שגיאה ליומנים מקומיים. יומנים אלה נשמרים רק על המחשב המקומי ולא נשלחים לשום מקום.

נספח

סיכום ממצאים

רכיב	סטטוס	פירוט
הצפנת פרטי התחברות	מאובטח	AES-256-CTR + scrypt, מפתח ב-OS Credential Store
שליפת עסקאות	מאובטח	מקומי בלבד (Puppeteer), סיסמאות רק לבנקים
סנכרון ל-MoneyMoney	מאובטח	עסקאות בלבד, חשבון מקוצר ל-4 ספרות, HTTPS
אבטחת Electron	מאובטח	הפרדת הרשאות, חסימת ניווט, הגבלת הרשאות
איסוף נתונים	אין	אפס אנליטיקס, אפס טלמטריה
קוד מקור	פתוח	ניתן לביקורת ציבורית ב-GitHub
קובץ עסקאות מקומי	שימו לב	לא מוצפן, נגיש למי שיש גישה למחשב
יומני שגיאות	שימו לב	נשמרים מקומית בלבד, לא נשלחים

דו״ח זה הופק על ידי Claude Opus 4.6 (Anthropic) על בסיס סקירת קוד המקור של MoneyMoney v1.0.16.
הקוד פתוח ונגיש לכל מי שמעוניין לבצע בדיקה עצמאית.

MoneyMoney © 2026 | קוד פתוח תחת רישיון MIT